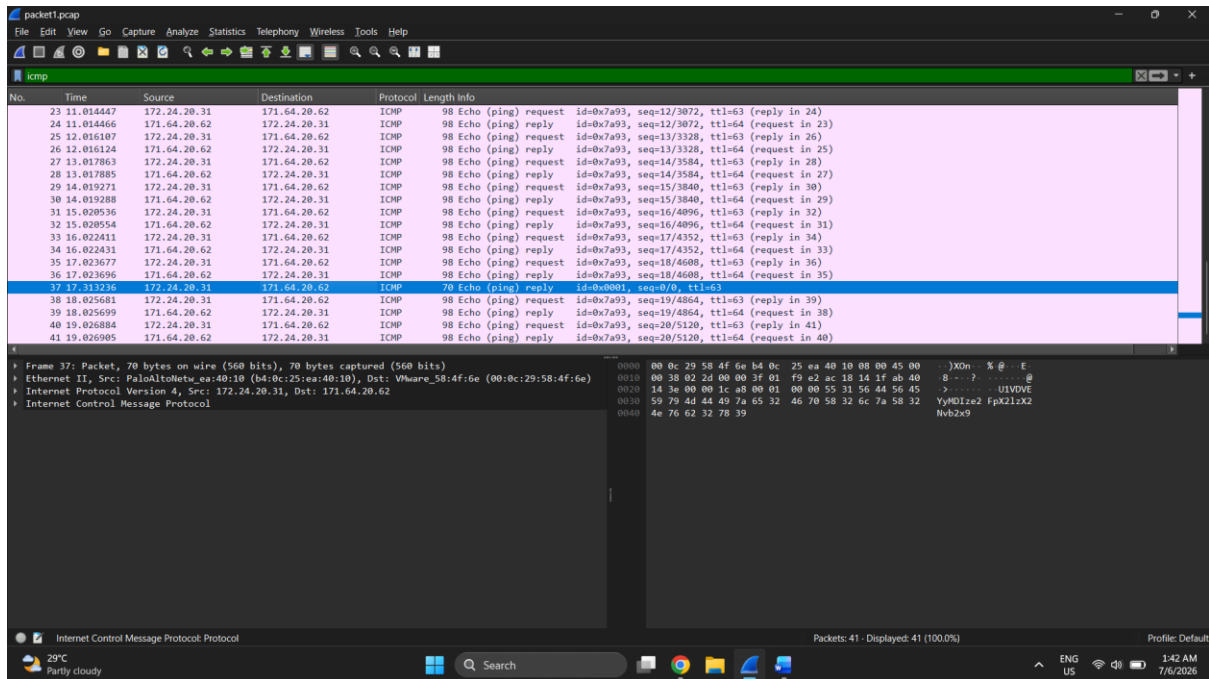


Muhamad Azim Mustaqim bin Azman

52215125078

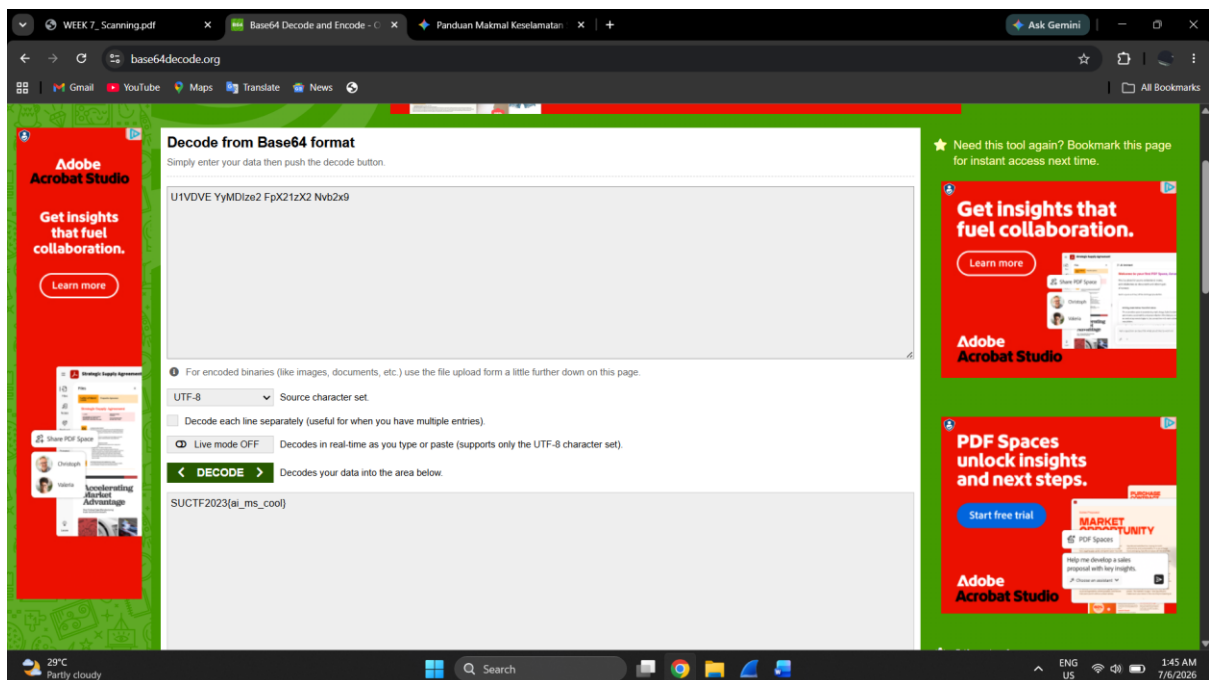
Lab Week 7

Question 1: Analyse packet1.pcap and find the flag



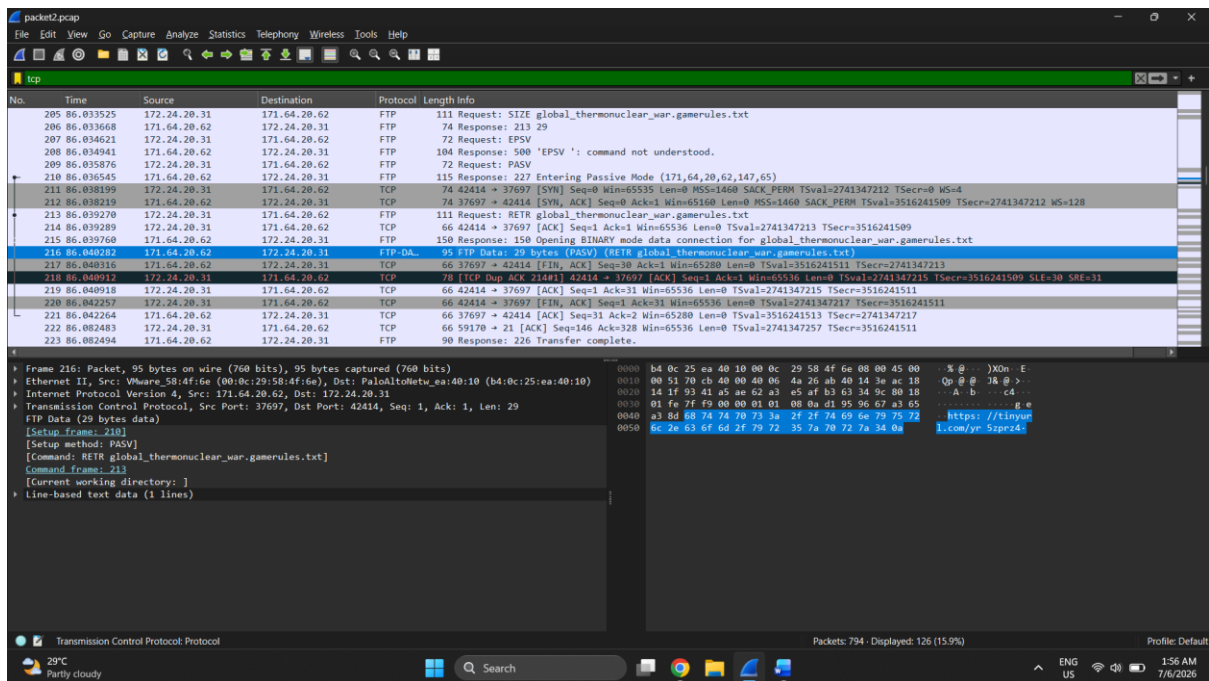
ICMP packet details reveal a string

The string “U1VDVE YyMDIze2 FpX21xX2 Nvb2x9” appear and need to decode by using Base64.

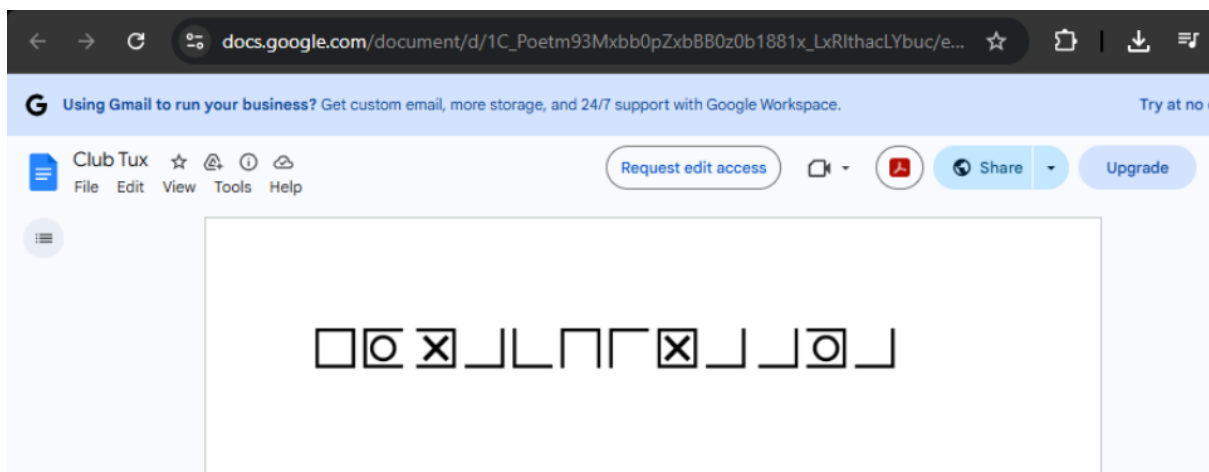


By using Base64 encoding, we finally successfully found the flag. The flag is SUCTF2023{ai_is_cool}

Question 2: Analyse packet2.pcap and find the flag.



Url has found, the URL is directing to a Google Docs



Question 3: Interpret an Nmap Output

1. What can an attacker do with each port?

- **Port 21 (FTP - vsftpd 2.3.4):** An attacker can attempt to intercept unencrypted traffic to steal login credentials. Since it runs a specific old version, an attacker can also trigger a known backdoor to gain instant access to the file system.
- **Port 22 (SSH - OpenSSH 5.3p1):** Attackers can launch automated brute-force attacks against this port to guess administrative passwords and gain a remote command shell. They can also target specific unpatched vulnerabilities within this older OpenSSH version.
- **Port 80 (HTTP - Apache 2.2.8):** This opens up the web server to web-application attacks such as Cross-Site Scripting (XSS), SQL Injection, or directory traversal. Attackers can also exploit outdated server modules to cause a Denial of Service (DoS).
- **Port 139 / 445 (SMB - Windows 7 Professional SP1):** These ports handle file sharing and network communication. An attacker can exploit them to move laterally across the network, access unauthorized network shares, or execute malicious code remotely.

2. What vulnerabilities are likely present based on the version?

- **vsftpd 2.3.4:** This specific version is famous for containing a **Backdoor Command Execution vulnerability (CVE-2011-2523)**. If an attacker sends a smiley face :) in the username, it opens a root shell on port 6200.
- **Apache 2.2.8:** This version is highly outdated and vulnerable to several issues, including the **Slowloris Denial of Service (DoS)** attack and various internal module exploits.
- **Windows 7 (SMB - Port 445):** Because the target is an unpatched Windows 7 Service Pack 1 system, it is critically vulnerable to **EternalBlue (MS17-010)**. This allows an attacker to execute code over the network without any user interaction.

3. Which one is the highest risk and why?

- **Answer: SMB (Port 445) running on Windows 7** is the highest risk.
- **Reason:** The EternalBlue vulnerability allows for **Remote Code Execution (RCE)** with system-level (administrative) privileges. It requires no user interaction, meaning the victim doesn't have to click anything. Furthermore, it is "wormable," meaning an infection on this machine could automatically spread to corrupt other vulnerable machines on the same network.

4. What attack path can be built from this?

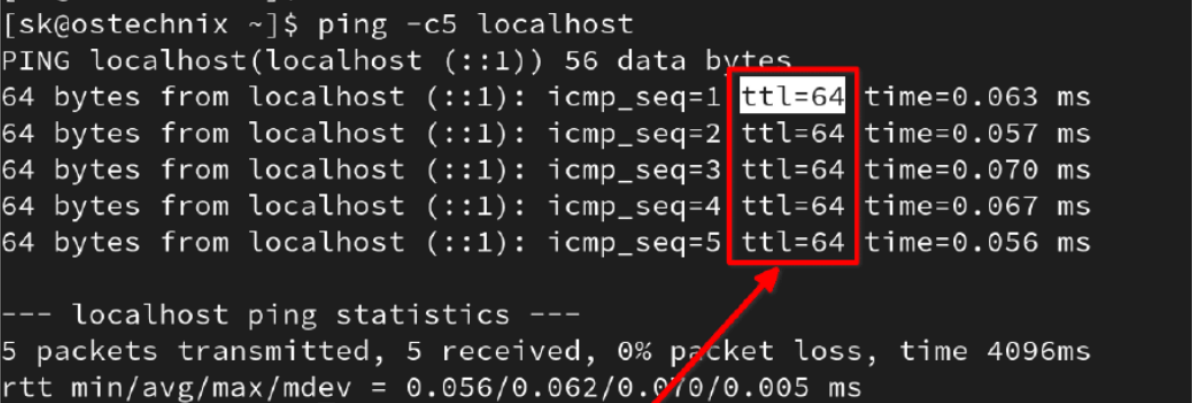
1. **Reconnaissance:** The attacker runs an Nmap scan and identifies that the target is an unpatched Windows 7 machine with port 445 open.
2. **Exploitation:** The attacker uses an exploitation framework like **Metasploit** to launch the `exploit/windows/smb/ms17_010_eternalblue` module against Port 445.
3. **Post-Exploitation:** Once the exploit succeeds, the attacker gains a high-privilege **Meterpreter shell**. From there, they can execute a credential dump (`hashdump`) to steal system passwords and use those credentials to log into other connected network systems (lateral movement).
- 4.

5. What should be the remediation?

- **Update/Patch:** Immediately apply the **MS17-010 security update** provided by Microsoft, or upgrade the outdated operating system to a modern, supported version like Windows 10 or Windows 11.
- **Disable Unnecessary Services:** Turn off SMBv1 completely on the system and close Port 21 if FTP file transfers are not strictly required for daily operations.
- **Upgrade Software:** Update the Apache web server and the OpenSSH server to their latest stable, patched versions to eliminate known vulnerabilities.

Question 4: Identify the OS (OS Fingerprinting) – TTL

Image 1



```
[sk@ostechnix ~]$ ping -c5 localhost
PING localhost (localhost (:::1)) 56 data bytes
64 bytes from localhost (:::1): icmp_seq=1 ttl=64 time=0.063 ms
64 bytes from localhost (:::1): icmp_seq=2 ttl=64 time=0.057 ms
64 bytes from localhost (:::1): icmp_seq=3 ttl=64 time=0.070 ms
64 bytes from localhost (:::1): icmp_seq=4 ttl=64 time=0.067 ms
64 bytes from localhost (:::1): icmp_seq=5 ttl=64 time=0.056 ms

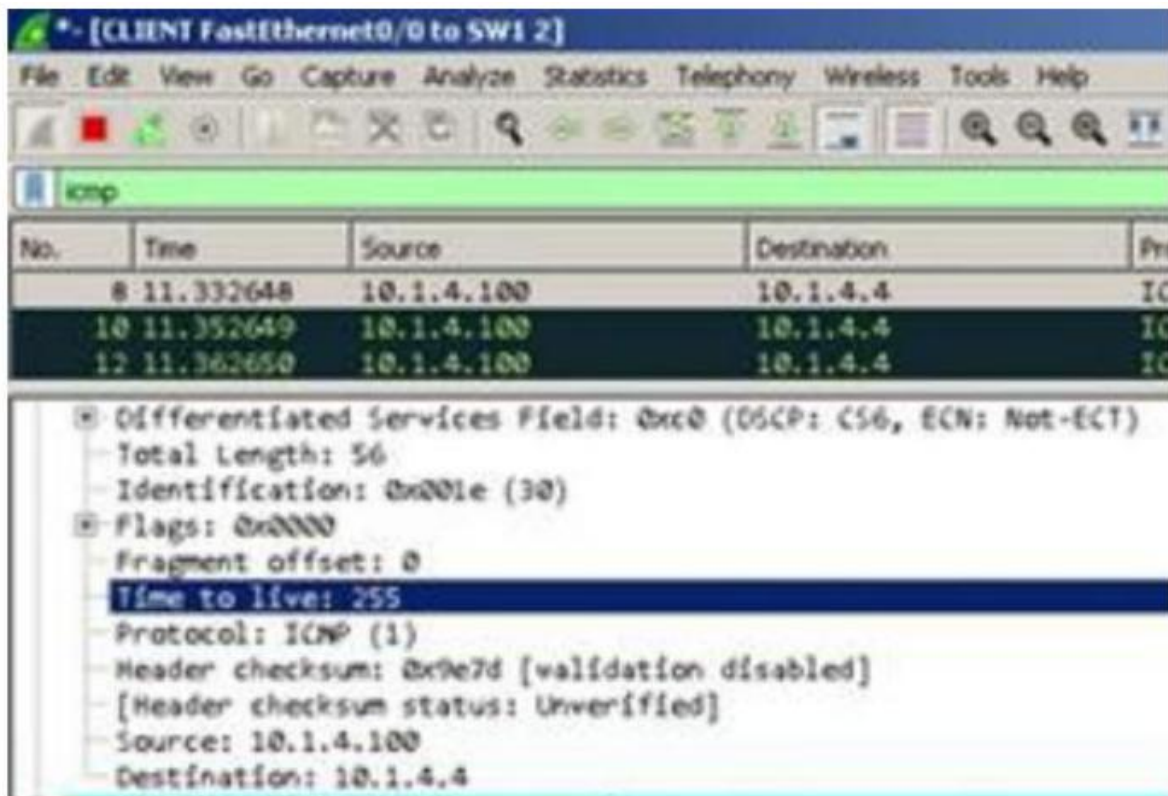
--- localhost ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4096ms
rtt min/avg/max/mdev = 0.056/0.062/0.070/0.005 ms
```

The terminal output shows the results of a ping command to localhost. The TTL value for all five packets is 64, which is highlighted by a red box. A red arrow points from the bottom of the box to the text 'Answer: Linux / Unix-based System'.

🔍 **Answer: Linux / Unix-based System**

🔍 **Reason:** The terminal screenshot shows successful ping responses where the **TTL value is exactly 64** (ttl=64). By default, modern Linux distributions (such as Ubuntu, Kali, and CentOS) as well as macOS use an initial starting TTL value of 64 for outbound IP packets.

Image 2



📌 **Answer: Cisco Router / Network Device**

📌 **Reason:** The Wireshark packet analysis panel explicitly highlights the packet's IP header detail, showing a **Time to live value of 255**. A default starting TTL value of 255 is the maximum limit possible in an IP header and is the standard baseline configuration used by Cisco routers, switches, and specialized network hardware devices.

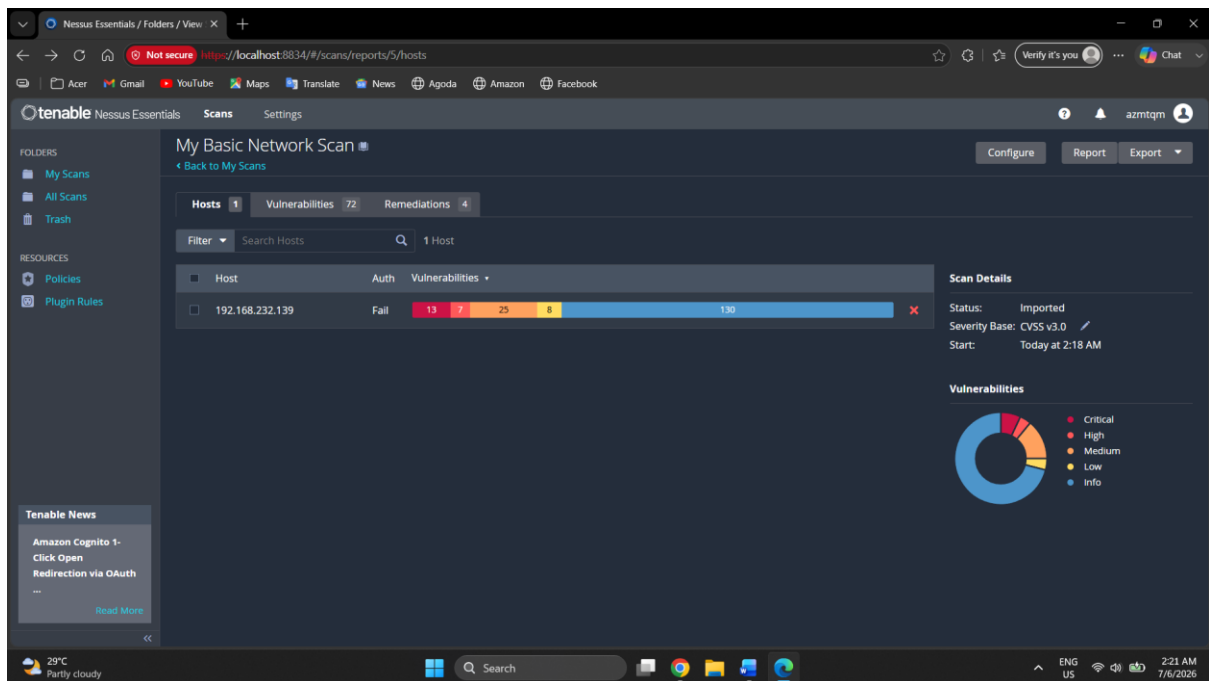
Image 3

```
64 bytes from 192.168.122.239: icmp_seq=1 ttl=128 time=6.85 ms
64 bytes from 192.168.122.239: icmp_seq=2 ttl=128 time=0.510 ms
64 bytes from 192.168.122.239: icmp_seq=3 ttl=128 time=0.601 ms
64 bytes from 192.168.122.239: icmp_seq=4 ttl=128 time=0.541 ms
64 bytes from 192.168.122.239: icmp_seq=5 ttl=128 time=0.558 ms
```

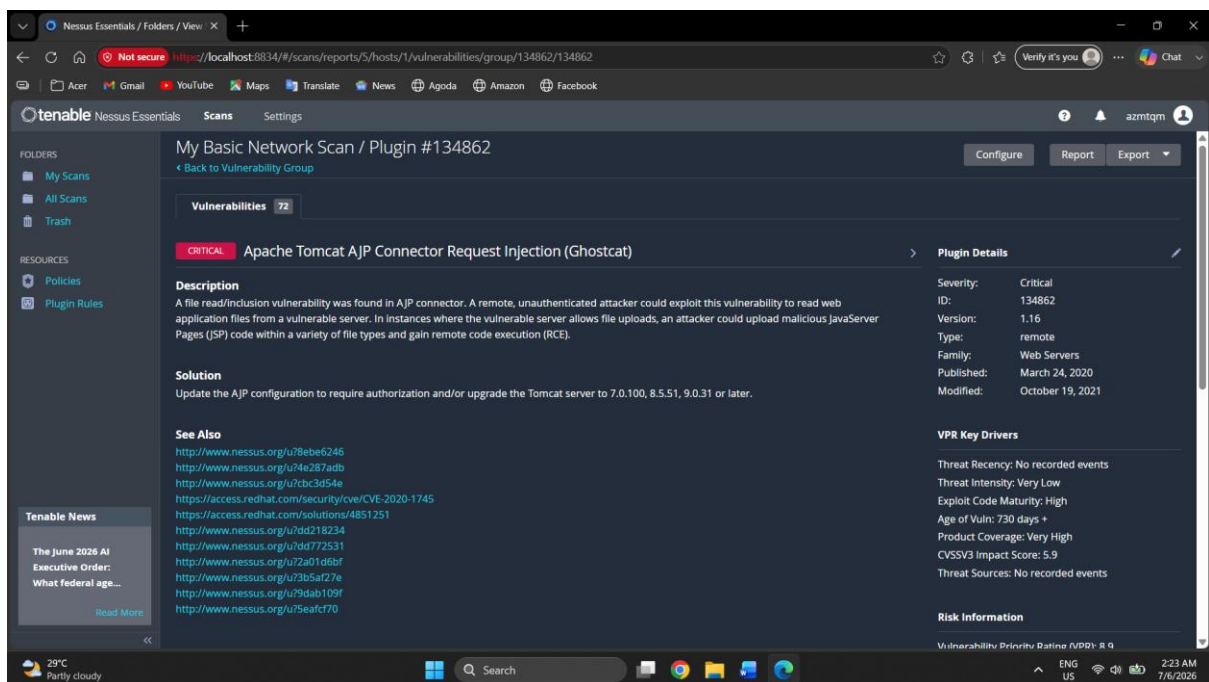
📌 **Answer: Microsoft Windows**

📌 **Reason:** The ping output sequence shows standard responses returning a **TTL value of 128** (ttl=128). Microsoft Windows operating systems (including Windows 7, 10, 11, and Windows Server editions) uniquely use a default baseline starting TTL value of 128 for network packet transmissions.

Question 5: Analyse the Nessus file



The file Network_scan.nessus was imported to Nessus successfully



Successfully found vulnerability for Ghostcat

1. Affected port number: 8009
2. Affected Protocol: Apache Tomcat AJP Connector Request Injection (GHOSTCAT)
3. CVSS Score of vulnerability found: 9.8 (Critical)

4. Can you find any exploit related to this vulnerability?

Vulnerability Information

CPE: `cpe:/a:apache:tomcat`

Exploit Available: true

Exploit Ease: Exploits are available

Patch Pub Date: March 1, 2020

Vulnerability Pub Date: March 1, 2020

Exploited by Nessus: true

5. Find CVE for this vulnerability.

Reference Information

CVE: [CVE-2020-1938](#), [CVE-2020-1745](#)